

ERASOA - ALUBIAS COMUNISTAS

Aurkitutako ahultasuna:

SQL Injection - MySQL
URL: http://localhost:81/login.php
Riesgo:  High
Confianza: Medium
Parámetro: iz_abz
Ataque: '
Evidencia: You have an error in your SQL syntax
CWE ID: 89
WASC ID: 19
Origen: Activo (40018 - Inyección SQL)
Vector de Entrada: Consulta de formulario
Descripción:
Inyección SQL puede ser posible.

Honen bidez, ondoriozta dezakegu webgunea SQL injection bidezko eraso bati ahula dela. Konkretuki, webgunean erabiltzaile atalean edozein erabiltzaile eta horren azkenean ' jarritz, SQL kodean kontsulta apurtzen dugu eta horren ondorioz errore bat eragiten dugu.

IZEN ABIZEN:

Ibai Gonzalez'

PASAHITZA:

.

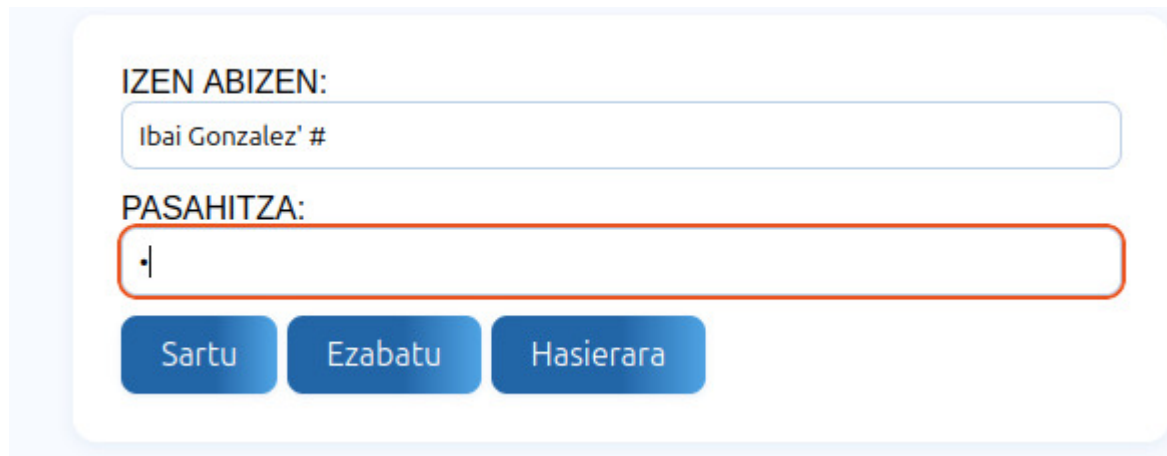
Sartu

Ezabatu

Hasierara

Fatal error: Uncaught mysqli_sql_exception: You have an error in your SQL syntax; check the manual that corresponds to your MariaDB server version for the right syntax to use near 'a' at line 1 in /var/www/html/php/login/index.php:19 Stack trace: #0 /var/www/html/php/login/index.php(19): mysqli_query(Object(mysqli), 'SELECT * FROM e...') #1 /var/www/html/login.php(3): require('/var/www/html/p...') #2 {main} thrown in /var/www/html/php/login/index.php on line 19

Horren ondorioz, berriro sartzean erabiltzailea eta ' # jarritz, edozein pasahitza jarri dezakegu, webgunera sartuko garela.



IZEN ABIZEN:

PASAHITZA:

Sartu Ezabatu Hasierara

Nola konpondu dezake?

Arazo hau 3 konponketa nagusi ditu. Alde batetik, datuak kontsultetan sartu eta gero haien egiaztapena gehitu dezakegu. Bestetik, *prepared statement* edo jadanik prest dauden kontsultak erabili dezakegu holan horiek ez dira SQL moduan interpretatuko eta ez dute kodea apurtuko. Eta azkenik egin dezakeena, SQL errorea ez erakustea da, horrela ez delako informaziorik emango erasotzaileei.